

Redes Privadas Virtuales (VPN) Parte 2

Experiencia Educativa: Seguridad en Redes
de Cómputo

MRT. Martha Elizabet Domínguez Bárcenas

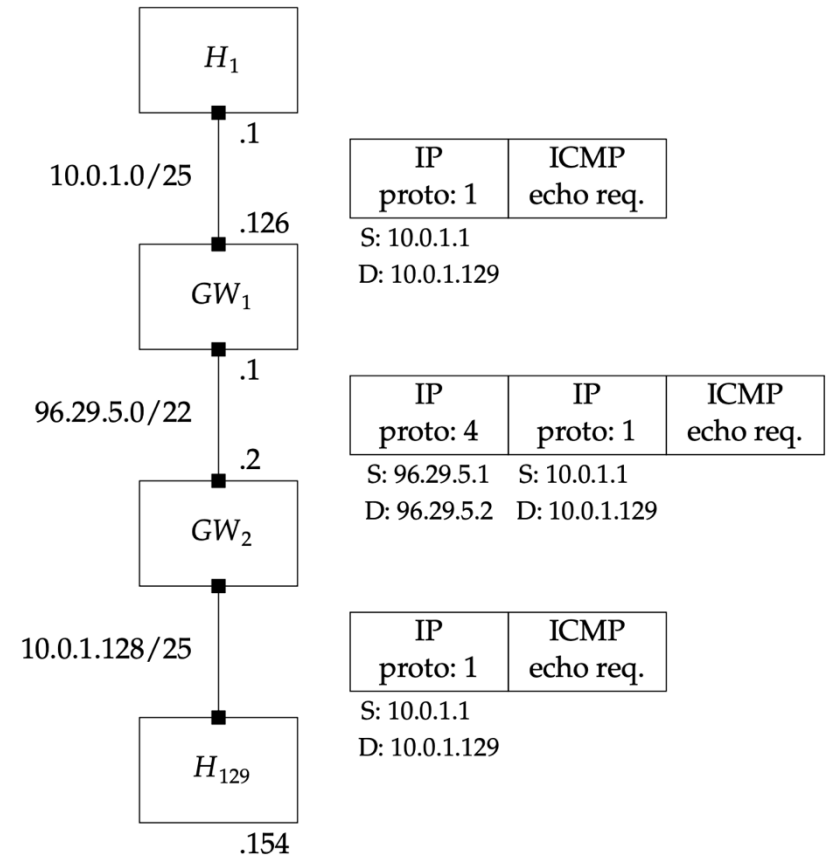
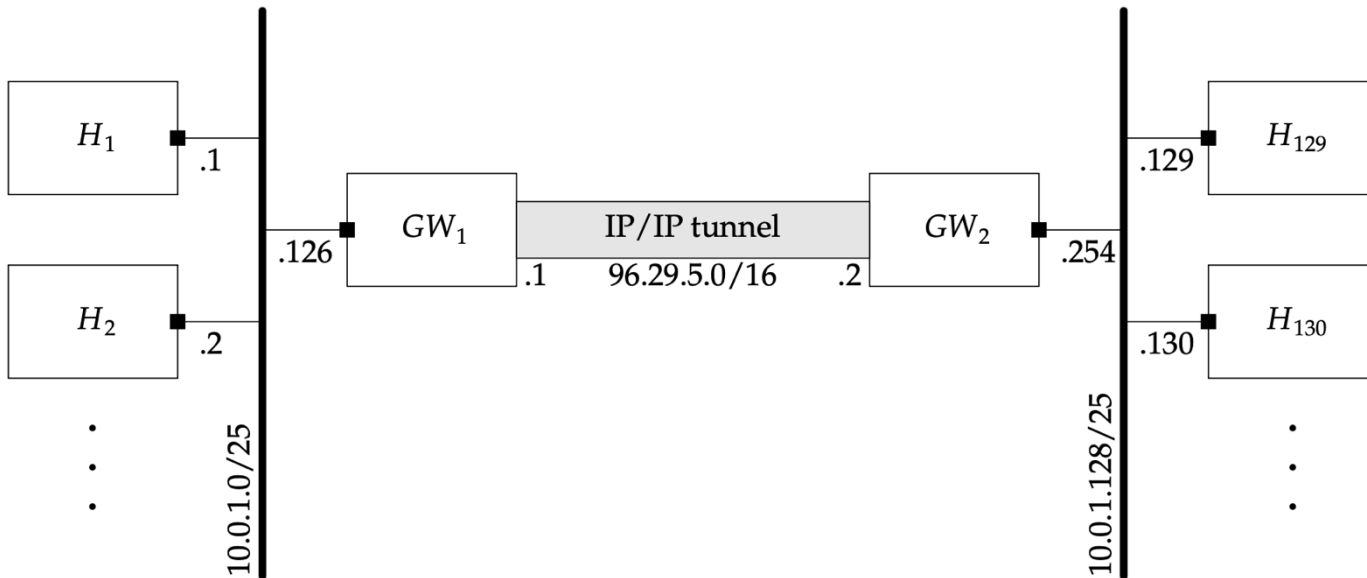
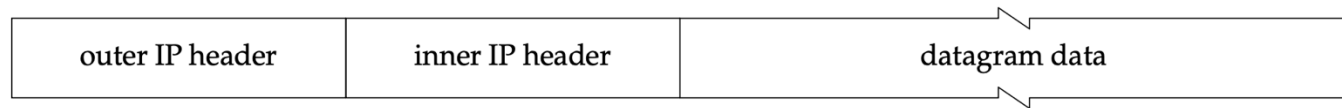


Túneles

- El tunneling o construcción de túneles consiste en la construcción de una red virtual sobre una red física
- Es el acto de encapsular los datos de un protocolo en los datos de otro protocolo de la misma capa o de una capa superior.
- Se dice que el protocolo de encapsulación es un túnel para el protocolo de capa inferior.
- A continuación se analiza la evolución de los protocolos de túnel.

Túneles IP-in-IP (1/2)

- Consiste en encapsular paquetes IP en otros paquetes IP
- Especificación definida en el RFC 2003

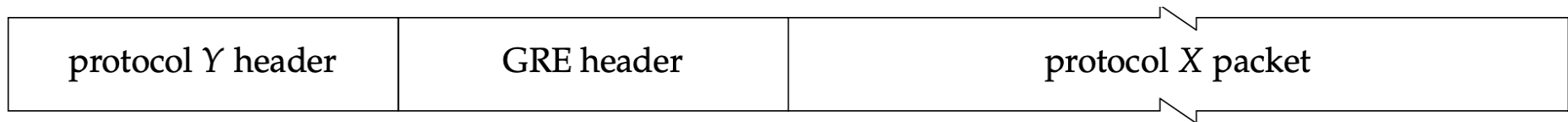


Túneles IP-in-IP (2/2)

- Algunos problemas relacionados
 - Aumento del tamaño de los encabezados (encabezado IP extra de al menos 20 bytes)
 - El paquete podría exceder la MTU de la interface
 - El peer tendría que realizar fragmentación de paquetes
 - Si el paquete original tiene activo el bit de control Don't Fragment (DF). El RFC 2003 especifica que esta misma bandera se debe configurar en el encabezado IP externo.
 - En caso de que el paquete exceda la MTU no podría fragmentarse. El peer simplemente no podría enviar el paquete.
 - El RFC 2003 recomienda que el peer informe al host que la fragmentación es necesaria, para que este pueda ajustar la MTU y los paquetes correspondientes.

Túneles GRE

- Generic Routing Encapsulation (GRE) agrega una interfaz de tipo GRE que agrega el encabezado al principio del paquete X y lo envía para su transmisión al protocolo Y.

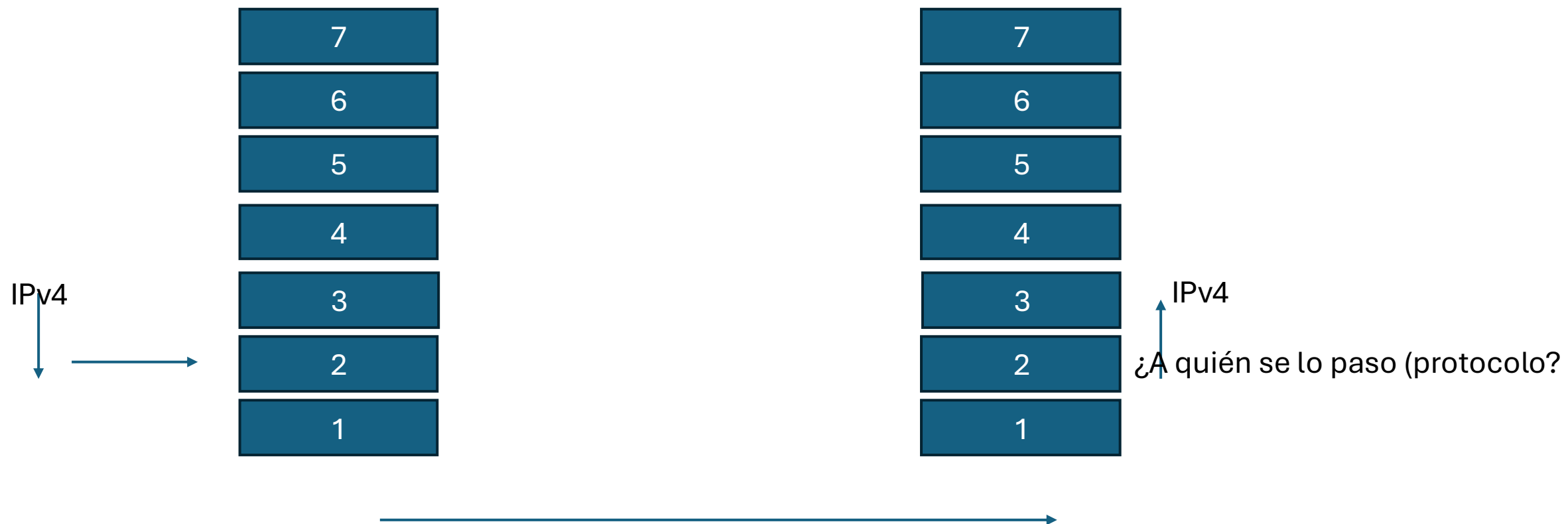


- En el peer remoto, la interfaz GRE recibe el paquete Y y lo desencapsula para enviar el paquete X a la capa correspondiente.

Encabezado GRE

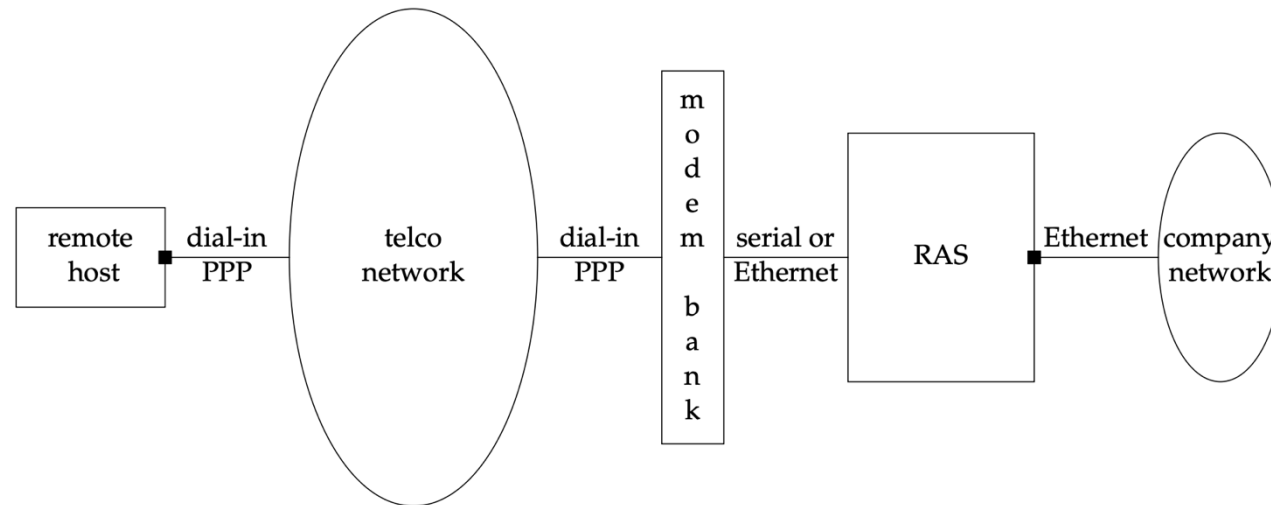
0	2	3	4					12	13			15	16					31
C			K	S	reserved ₀						version		protocol type					
checksum (optional)												reserved ₁ (optional)						
key (optional)																		
sequence number (optional)																		

- Campos del encabezado:
- **C**, indica que está presente el campo **checksum**. Si la bandera está activa, también se utilizará el campo **reservado₁**
 - El checksum se calcula sobre el encabezado de GRE y su payload
- **K**, indica que el campo **key** estará presente
 - Necesario para identificar un flujo de tráfico particular en el túnel
- **S**, indica que el campo número de secuencia estará presente.
 - Para proporcionar una entrega ordenada del payload (aunque no garantizada)
 - Permite descartar paquetes con el mismo número de secuencia o poner en una cola de espera paquetes con números de secuencia mayores al esperado
- **Versión**, indica el número de versión, originalmente valor 0 (depende del protocolo con el que se use, p.ej., PPTP, valor 1)
- **Protocol type**, indica el protocolo al que va dirigido el payload del paquete. Cuando se usa Ethernet en capa 2, este valor es equivalente al valor del campo Type en Ethernet.



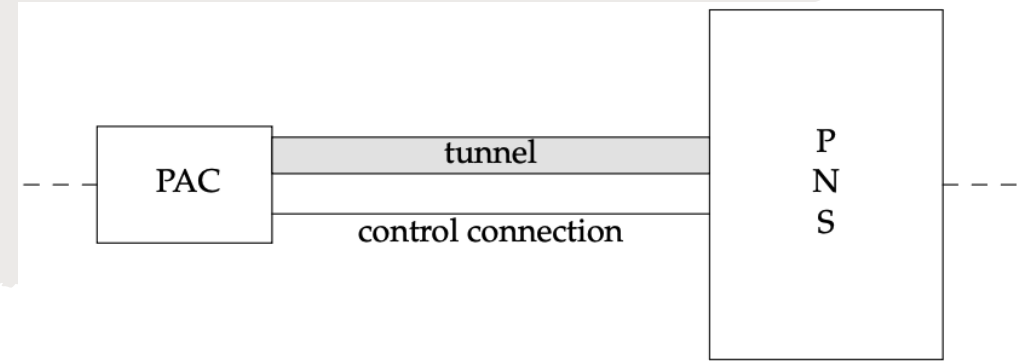
PPTP (1/3)

- Point-to-Point Tunneling Protocol (PPTP)
- Utilizado para túneles de acceso remoto sobre líneas telefónicas que utilizan el **Protocolo Punto a Punto (PPP) a nivel de capa 2**
- Requiere el uso de un Servidor de Acceso Remoto (RAS)



- El RAS se encarga de asignar una dirección IP de la organización para el host remoto

PPTP (2/3)



- PPTP divide las funciones del RAS en:
 - **PPTP Access Concentrator (PAC)**, utilizada por el usuario que marca
 - **PPTP Network Server (PNS)**, termina las sesiones de clientes PPP y proporciona acceso a la red de la organización
- La dupla PAC-PNS proporciona el túnel para el flujo de paquetes entre el host remoto y el PNS
 - El PAC puede ser parte del host remoto, o bien, un host de la organización
 - El usuario remoto establece conexión con el PNS, que proporciona acceso a la red de la organización.
 - El rol del PAC es transferir paquetes PPP entre el host remoto y el PNS a través del túnel.

PPTP (3/3)

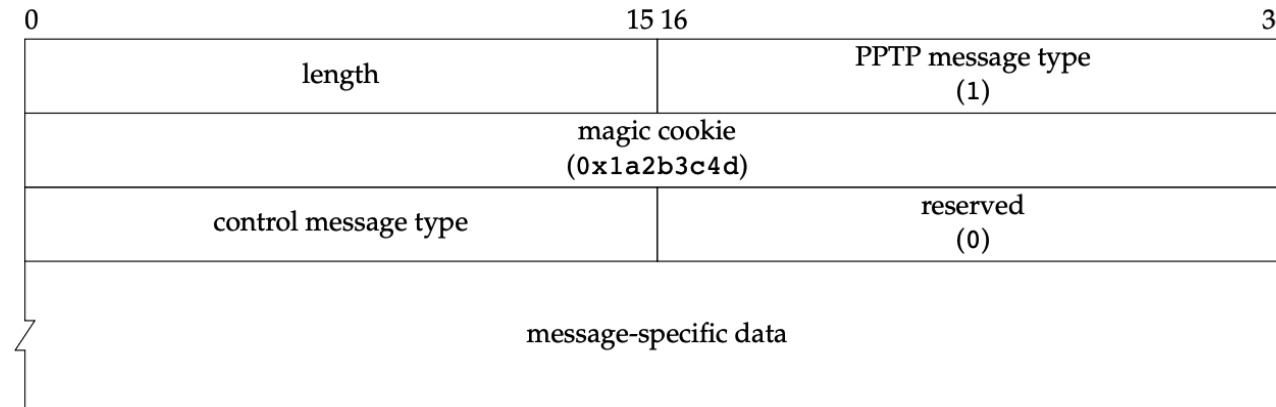


Para el control de la conexión, el PAC y el PNS inician una conexión TCP al puerto 1723.



Una vez establecida la conexión se intercambian mensajes de control PPTP (gestión del control de la conexión, gestión de llamadas, reporte de errores, entre otros)

Encabezado PPTP



Campos del encabezado:

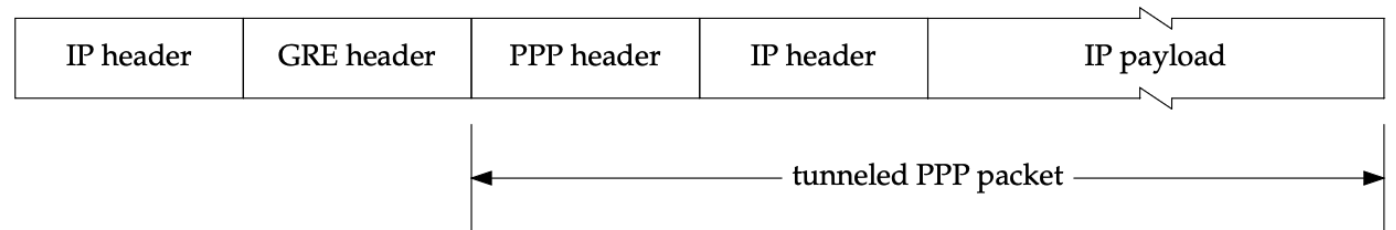
- **Length**, es la longitud del mensaje PPTP, incluyendo el encabezado
- **Message type**, valor 1 si se trata de un mensaje de control
- **Magic cookie**, siempre tiene el valor 0x1a2b3c4d, se utiliza para la sincronización con el flujo TCP. Si el mensaje no contiene este valor, el receptor sabe que ha perdido la sincronización
- **Control message type**, indica el tipo de mensaje de control y el formato del resto del mensaje. Utilizado para:
 - iniciar (Start-Control-Connection-Request, Start-Control-Connection-Reply)
 - terminar (Stop-Control-Connection-Request, Stop-Control-Connection-Response)
 - y probar la conectividad (Echo-Request).

Túnel PPTP (1/4)

- El túnel establecido es un túnel GRE que encapsula paquetes PPP (versión extendida de GRE)

Cambios:

- Campo adicional: **acknowledgment number**
- Bit adicional: **A**. Indica si está presente el campo ACK
- Campo **key**, se divide en **payload length** (longitud del payload) y **call id** (para identificar la conexión).



0	1	2	3	4	7 8 9				12 13	15 16	31									
0	0	1	S	reserved ₀ (0)				A	reserved ₁ (0)				version (1)		protocol type					
payload length													call ID							
sequence number (optional)																				
acknowledgment number (optional)																				

Túnel PPTP (2/4)

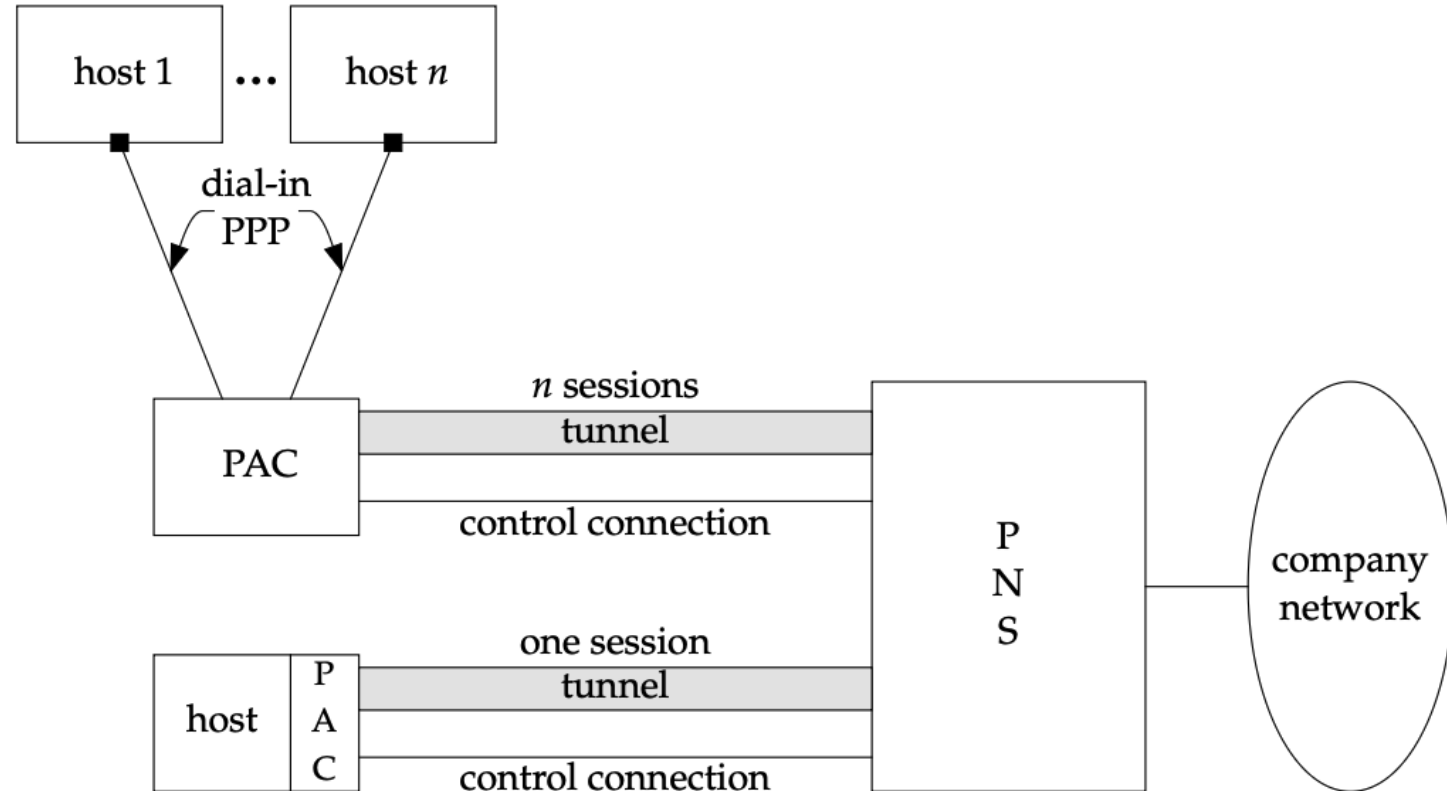
Modo obligatorio (Mandatory)

Los usuarios se conectan mediante PPP a un servidor de acceso telefónico – por ejemplo, de un ISP –

Los usuarios no se dan cuenta que utilizan un túnel

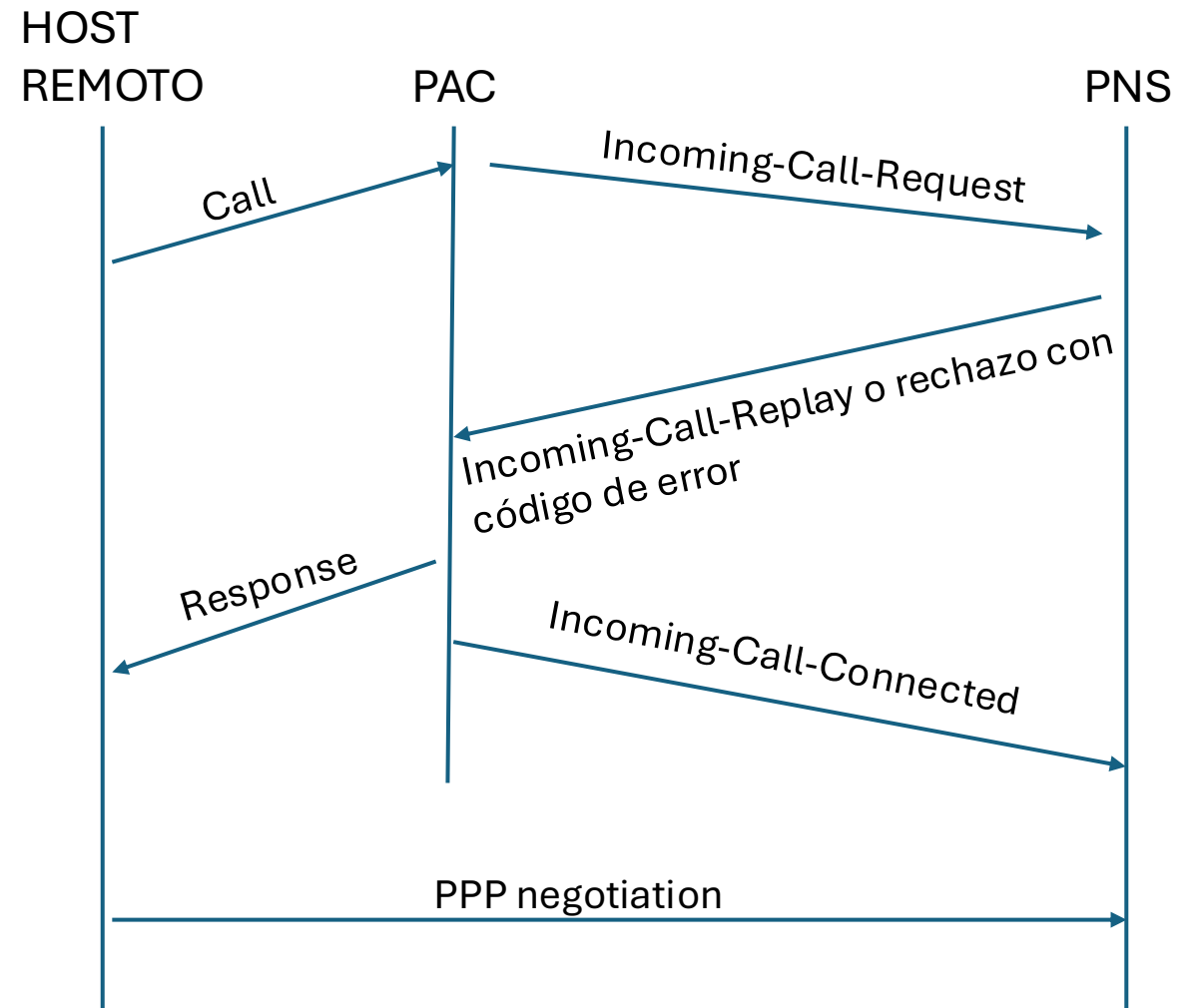
Modo voluntario (Voluntary)

El host remoto está directamente involucrado en el mecanismo del túnel y puede elegirse si lo usa.



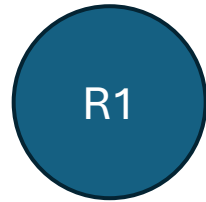
Túnel PPTP (3/4)

- Cuando un host remoto se conecta al PAC, el PAC envía un Incoming-Call-Request al PNS
- El PNS responde con un Incoming-Call-Replay aceptando la llamada o bien, especificando un código de error para rechazarla
- Cuando el PAC recibe el Incoming-Call-Replay, puede responder la llamada del host
- El PAC completa el establecimiento de la sesión enviando un mensaje Incoming-Call-Connected al PNS. En este punto, el host remoto y el PNS inician la negociación PPP (PPP LCP)



Túnel PPTP (4/4)

- PPTP es un tipo de servidor de acceso remoto que no requiere gran inversión
- No utiliza mecanismos de cifrado o autenticación
- PPTP es un protocolo de túnel, no un protocolo de VPN
- PPTP confía en el protocolo subyacente (PPP) para los servicios de cifrado y autenticación
- No hay autenticación por paquete. Esto implica que puede haber ataques de manipulación de bits sobre datos cifrados



User	Pass
R2	*****

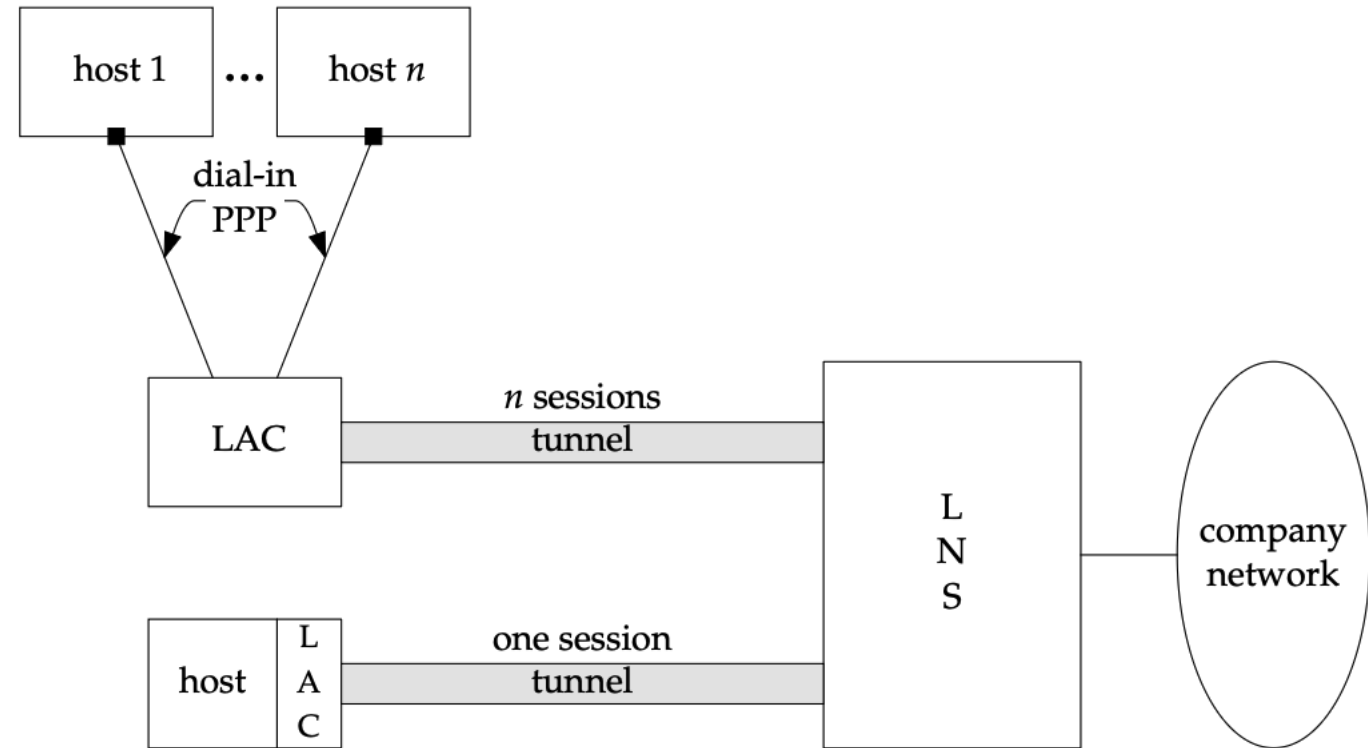
User	Pass
R1	*****

L2TP

- PPP utiliza TCP para controlar el canal, restringiendo su uso a redes IP
- Cisco desarrollo un protocolo propietarios llamado Layer Two Forwarding (L2F), similar a PPTP, pero que podía operar sobre un protocolo de capa de enlace
- El IETF combinó las ideas de PPTP y L2F para crear un protocolo llamado **Layer two Tunneling Protocol (L2TP)**
- El objetivo de L2TP es dividir las funciones del RAS en dos partes:
 - **L2TP Access Concentrator (LAC)**. Maneja la comunicación física con el host remoto
 - **L2TP Network Server (LNS)**. Actúa como gateway en la red privada

L2TP

- L2TP puede operar en:
 - Modo Mandatory. El host remoto se conecta a un LAC autónomo
 - Modo Voluntary. El LAC reside en el host remoto
- Diferencias con PPTP
 - No existe una conexión independiente entre LAC y LNS
 - La información de control se envía a través del mismo túnel
 - Permite conexiones distintas a PPP
 - El control de conexión es independiente de TCP



Encapsulamiento L2TP

- En lugar de usar GRE, L2TP utiliza datagramas UDP. Esto facilita la interoperabilidad de L2TP con NAT
- El encabezado L2TP incluye información sobre la sesión
- Hay dos tipos de mensajes
 - **Mensajes de control.** Conexiones usadas para establecer y gestionar el túnel L2TP, iniciar y terminar sesiones de usuario
 - **Mensajes de datos.** Conexiones que llevan paquetes de datos (por ejemplo, frames PPP) del host remoto al LNS

Encabezado L2TP

- Ambos tipos de mensajes inician con un encabezado común
- El **encabezado es ampliable** en dos sentidos
 - Muchos de los **campos** son **opcionales**
 - Se pueden agregar **campos adicionales**, dependiendo del tipo de información que lleve el mensaje. Estos campos adicionales son en forma de tipo-longitud-valor, por lo que reciben el nombre de **Par de Atributo Valor (AVP)**, por sus siglas en inglés)

Encabezado L2TP

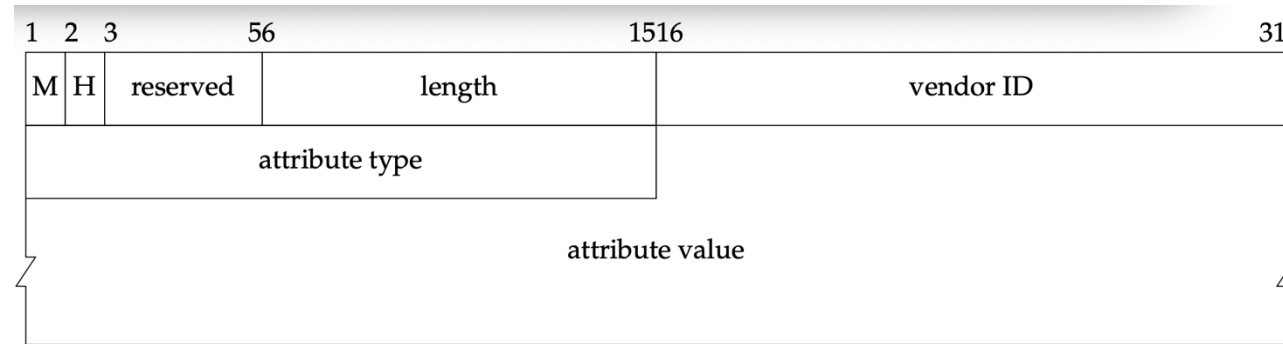
0	1			4		6	7							13		15	16													31
T	L	x	x	S	x	O	P	x	x	x	x	x	version	length (optional)																
tunnel ID														session ID																
Ns (optional)														Nr (optional)																
offset size (optional)														offset pad (optional)																

Descripción de los campos:

- **T**, permite distinguir los mensajes de control de los mensajes de sesión. Se establece un valor para los mensajes de control y se deja en blanco para otro tipo de mensajes
- **L**, indica que está presente el campo longitud. Siempre fijado en los mensajes de control, opcional para otro tipo de mensajes
 - Length, especifica la longitud total del mensaje, incluyendo el encabezado. Puede ser de hasta 65,535 bytes, pero con redes IP, se debe ajustar al campo longitud (de 16 bits) de IP.
- **S**, indica si están presentes los campos Número de secuencia: Ns y Nr. Siempre presentes para los mensajes de control.
 - Uso equivalente a los campos Sequence Number (Ns) y ACK de TCP (Nr)
- **O**, indica si el campo Offset está presente. Siempre en blanco para mensajes de control
- **P**, indica que el mensaje debe tener prioridad para encolamiento y transmisión en la máquina local (por ejemplo para mensajes keep-alive). En blanco para mensajes de control.
- **Version**, siempre con valor 2 para mensajes L2TP
- **Tunnel ID**, identifica un túnel en particular
- **Session ID**, identifica una sesión particular a la que pertenece el mensaje de datos
- **Offset size y Offset pad**, se usan para rellenar el encabezado, si es necesario. Offset size indica el número de bytes después de este campo, donde inician los datos. Estos campos no están presentes en los mensajes de control.

Par de Atributo Valor (AVP)

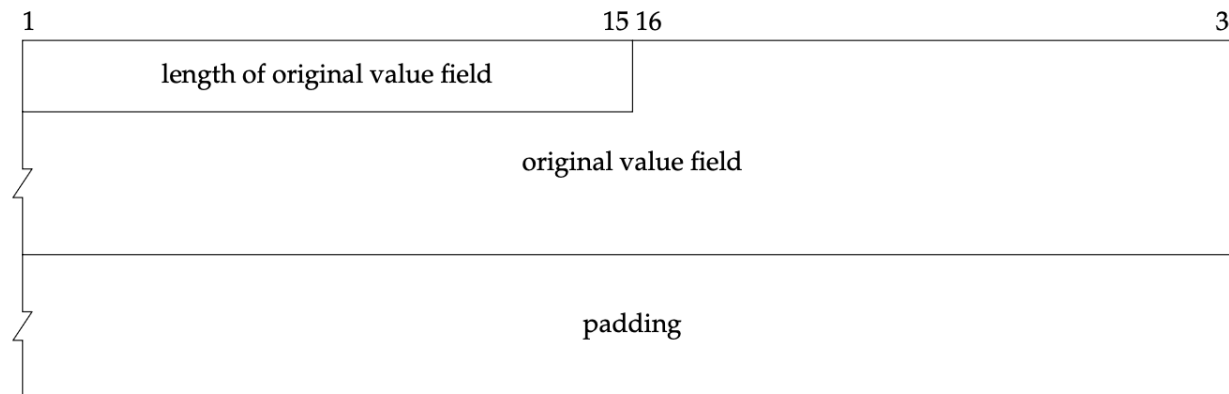
- **Campos en los mensajes de control**, distintos a los del encabezado común



- **M**, indica que este AVP es obligatorio (mandatory). Si no es establecido, el receptor debe ignorar el AVP
- **H**, *hidden bit*, indica que este **AVP está cifrado**. Se utiliza **para transmitir passwords y otros parámetros sensibles**.
- **Length**, número de bytes en el AVP
- **Vendor ID**, valor 0 indica que los valores de los tipos de atributos son los definidos en la especificación L2TP (RFC 2661). Los proveedores pueden obtener su propio vendor ID del IETF (con atributos propietarios)
- **Attribute type**, campo de 16 bits que especifica que parámetros de este AVP se están llevando
- **Attribute value**, indica el valor de los parámetros correspondientes

Cifrado de AVPs (1/2)

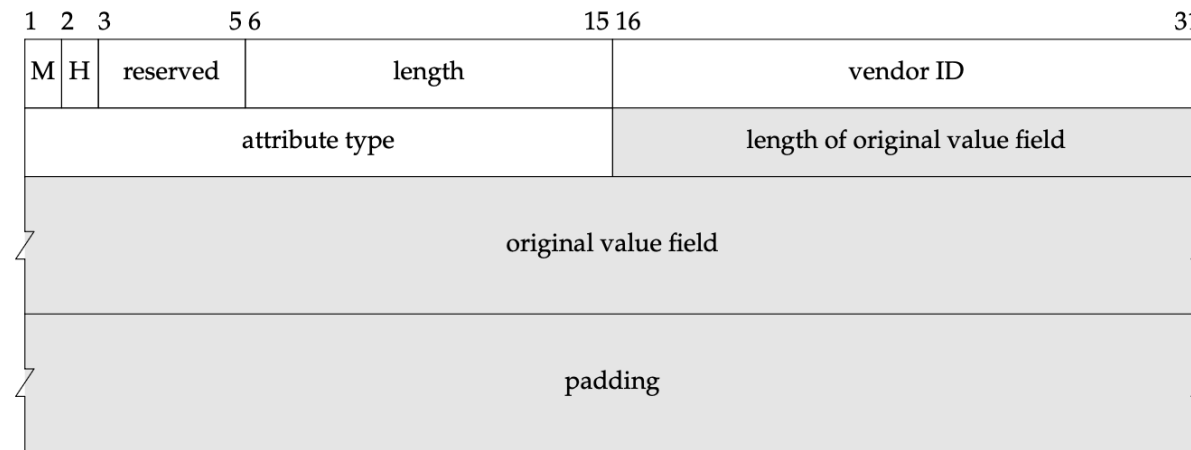
- Para que tenga lugar el cifrado, LAC y LNS deben tener una **clave compartida**
- Un mensaje que tiene un hidden AVP (AVP cifrado), debe tener un ***random vector***, que será utilizado como parte de la llave para el proceso de cifrado
- El AVP se codifica de la siguiente manera



- **Original length**, contiene la longitud original del campo valor (que quedará oculta por el padding y el cifrado)
 - Usado por el receptor para poder descartar el padding y quedarse con el valor original
- **Padding**, cantidad arbitraria de relleno para ocultar la longitud original

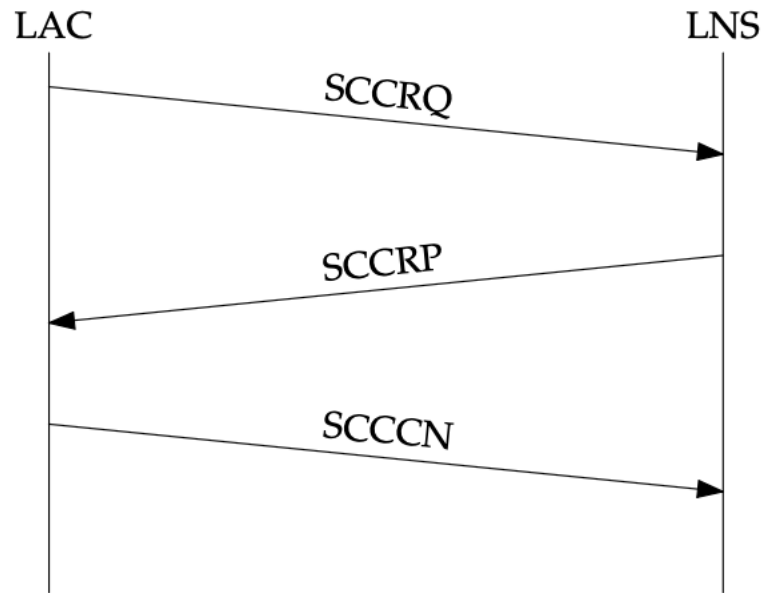
Cifrado de AVPs (2/2)

- AVP final después de cifrar (solo se cifra la porción sombreada):



- El cifrado se realiza contatenando:
 - Los 2 bytes de **attribute type**
 - El **secreto compartido**
 - La longitud arbitraria del ***random vector***
- Después se toma el hash MD5 del resultado.

Establecimiento del túnel L2TP



SCCRQ – Start-Control-Connection-Request

SCCRP - Start-Control-Connection-Reply

- Si el peer **rechaza la conexión** responde con un StopCCN y el código de error correspondiente.
- Si los **parámetros** del SCCRCP son **aceptables** para el iniciador del túnel, envía un SCCCEN

SCCCN – Start-Control-Connection-Connected

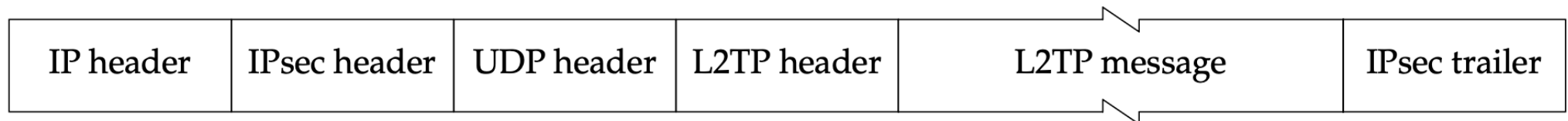
- Si **no son aceptables**, responde con un StopCCN
- Si se recibe el SCCCEN, el túnel queda establecido

Túnel L2TP

- L2TP tiene una **seguridad integrada mínima**
- El LAC y el LNS se pueden autenticar durante la configuración del túnel y los AVPs se pueden cifrar, pero al igual que PPTP, la **protección de los datos del usuario en el túnel dependen de PPP**
- PPP maneja dos tipos de **autenticación** para el establecimiento de la sesión: Password Authentication Protocol (PAP) y Challenge Handshake Authentication Protocol (CHAP). También puede manejar **cifrado** de tramas.
- **Ni los mensajes PPP, ni los mensajes L2TP son autenticados**, por lo que podrían ser sujeto de varias manipulaciones.
- Algo importante a resaltar: el cifrado No provee autenticación de mensajes. Por lo que aún los mensajes cifrados podrían ser manipulados por un atacante
- Un atacante podría responder mensajes previos para confundir al protocolo o a la aplicación
- Otro problema es el uso de una **clave compartida** para la autenticación de los endpoints. Si la clave se ve comprometida, todo el tráfico anterior y futuro podría ser leído.
- La **clave compartida** tienen una larga vida (**no se actualiza**). Si un atacante acumula grandes cantidades de datos cifrados. Podría llegar a descubrir la llave con un criptoanálisis.

L2TP e IPsec

- Debido a las debilidades de seguridad que presenta, muchos expertos consideran a L2TP una tecnología de acceso remoto, más que una VPN
- Sin embargo, los usuarios tienden a pensar en L2TP como una tecnología para proteger sus comunicaciones
- Solución: Combinar L2TP con un protocolo externo de seguridad (L2TP sobre IPsec)
- IPsec proporciona cifrado, autenticación y otros servicios de seguridad en la capa de red. Particularmente con el uso de Encapsulating Security Payload (ESP), donde el payload del paquete IP es cifrado y autenticado mientras se transmite entre LAC y LNS



OpenVPN

- Ofrece seguridad comparable con IPsec
- Utiliza TLS/SSL para la autenticación de los endpoints y el intercambio de claves
- Logra un comportamiento similar a ESP para el canal de datos.

SSL

- Secure Sockets Layer
- Considerado el protocolo de túnel de capa de transporte más omnipresente
 - Conocido por permitir conexiones seguras en la Web (HTTPS)
 - Tiene muchas otras aplicaciones y puede utilizarse para construir túneles de capa de transporte de propósito general
- Especificación originada en 1994 por la empresa Netscape, interesada en una forma de asegurar ciertas transacciones realizadas con su navegador web del mismo nombre
- Versión 2 (SSL 2 liberada en el mismo año)

SSL

- SSL 2 tuvo algunos problemas de seguridad
- En 1995 Netscape libera la versión 3 (SSL 3) completamente reescrito
- En 1996 el IETF intenta estandarizar el protocolo y por razones políticas, fue nombrado Transport Layer Security (TLS)
 - Basado en SSL3 pero con algunos pequeños cambios que lo hacen incompatible
 - Primer RFC publicado en 1999, RFC 2246 (TLS, versión 1)
 - Última versión, 1.3, RFC 8446 (agosto 2008)
 - Nota: Algunas funciones críticas para el rendimiento, como HTTP/2, requieren explícitamente el uso de TLS 1.2 o superior
- Por costumbre, se sigue utilizando el acrónimo SSL para referirse tanto a SSL como a TLS

TLS

- La motivación de Netscape al crear SSL fue garantizar la seguridad de las transacciones de comercio electrónico en la web.
- Requería
 - **Cifrado** para proteger los datos personales de los clientes
 - **Autenticación** y garantías de **integridad** para asegurar una transacción segura
- SSL se implementó en la capa de aplicación, directamente sobre TCP
 - Permite que distintos protocolos de aplicación (HTTP, correo electrónico, mensajería instantánea, entre otros) funcionaran sin cambios, a la vez que proporcionaban seguridad en la comunicación

Servicios esenciales de TLS

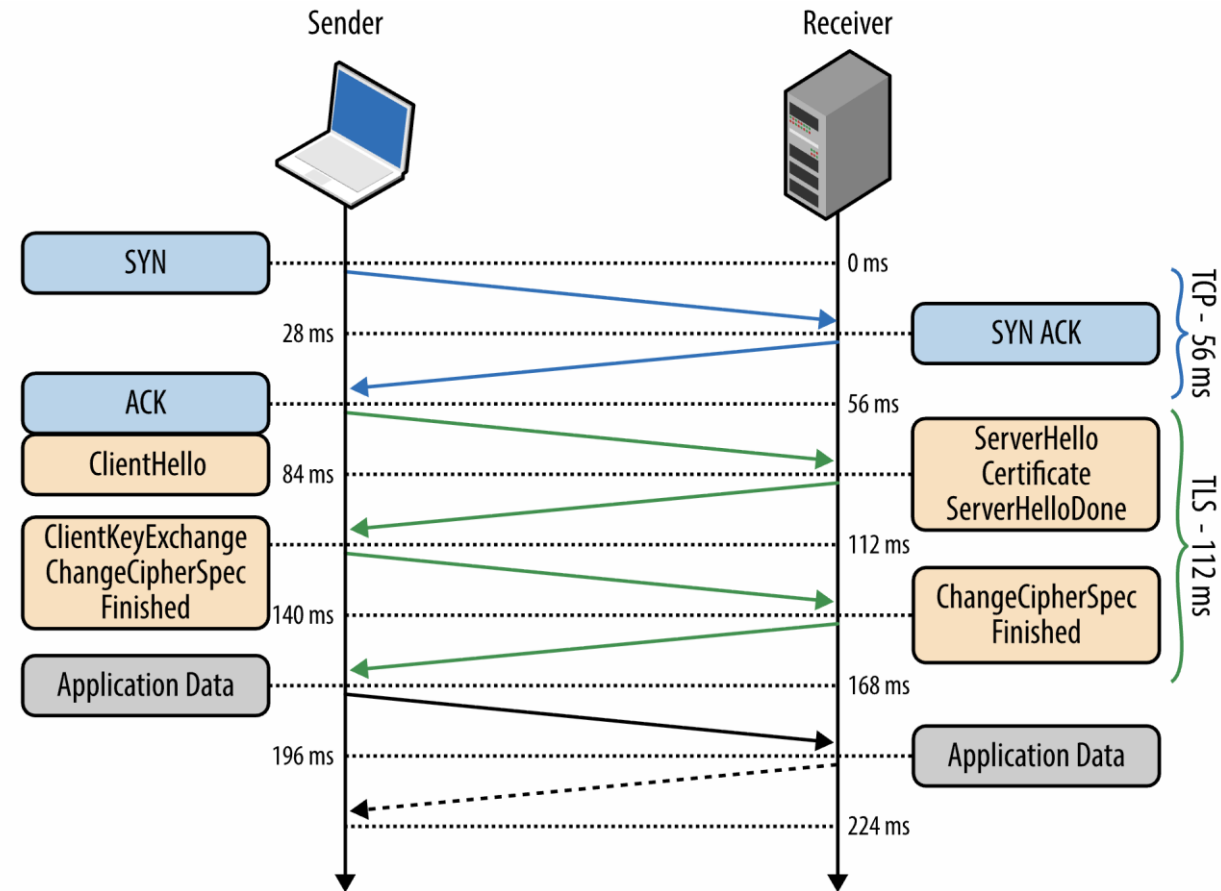
- Cifrado
 - Para ocultar información que se envía (confidencialidad)
- Autenticación
 - Para verificar la validez del material de identificación proporcionado
- Integridad
 - Para detectar posible manipulación y falsificación de mensajes
- Se puede optar por no utilizar todas las características, aceptando los riesgos que esto implica

Requisitos de TLS

- Los peers deben acordar
 - Conjuntos de cifrado (**Cipher Suits**)
 - Claves para encriptar datos
- Requieren la negociación de la clave secreta, utilizando criptografía de clave pública (o de clave asimétrica)
- Ambos peers pueden **autenticar** su identidad
 - Esta verificación se basa en la **cadena de confianza** establecida
 - **Autoridades de certificación**
- TLS proporciona un mecanismo de enmarcado de mensajes y firma de cada mensaje con un Código de Autenticación de Mensaje (MAC), con el uso de algoritmos de hash (**integridad**)

TLS Handshake

- El intercambio de datos de la aplicación mediante TLS requiere la negociación previa de un túnel de cifrado.
- Cliente y servidor deben acordar:
 - La versión de TLS a utilizar
 - Elegir el conjunto de cifrado (**Cipher Suit**)
 - Verificar los certificados (opcionalmente, el servidor también podría solicitar certificado al cliente)
- Se realiza el handshake de TCP
- Cliente envía versión de TLS, lista de conjuntos de cifrado compatibles y otras opciones de TLS que se desee utilizar (Client Hello).
- Servidor selecciona versión de TLS, elige un conjunto de cifrado, adjunta su certificado y envía respuesta al cliente (Server Hello).
- Si el cliente está satisfecho con el certificado del servidor, inicia el intercambio de claves (RSA o Diffie- Hellman) para establecer la clave simétrica.
- Servidor procesa parámetros de intercambio de claves, comprueba la integridad del mensaje (MAC) y devuelve un mensaje Finished cifrado al cliente.
- Cliente descifra mensaje con la clave simétrica conocida, verifica la integridad (MAC) y si todo es correcto, se establece el túnel y comienza el envío de datos de la aplicación



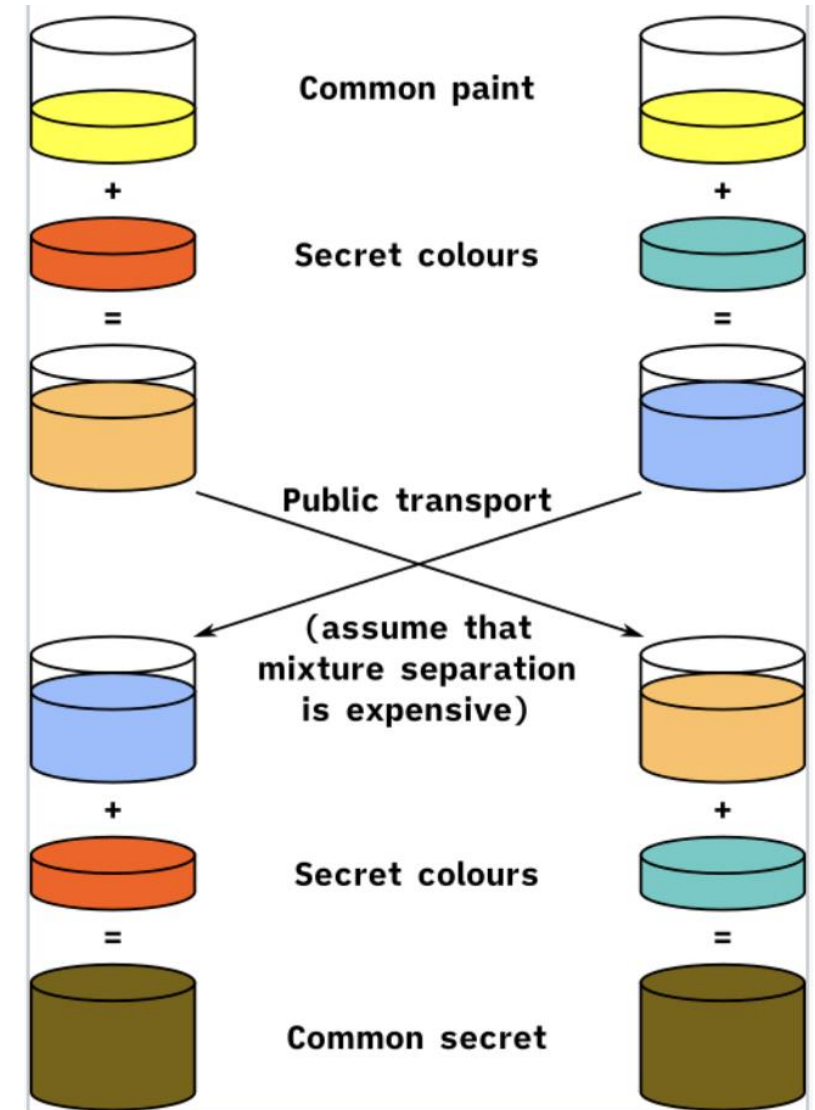
Nota: otro aspecto que se negocia durante el handshake es el protocolo de aplicación a utilizar

RSA

- Sistema criptográfico de clave pública o asimétrica, de Rivest, Shamir y Adleman.
- Mecanismo de **intercambio de claves** predominante en la mayoría de las implementaciones de TLS
 - Cliente genera una clave simétrica
 - Cliente cifra clave simétrica con la clave pública del servidor y la envía
 - Servidor utiliza su clave privada para descifrar clave simétrica recibida
- Esta clave simétrica negociada se utiliza para cifrar su sesión
- Vulnerabilidad:
 - RSA utiliza el mismo par de claves pública-privada para intercambio de claves y para autenticar al servidor
 - Si un atacante tuviera acceso a la clave privada del servidor, podría descifrar toda la sesión.

Diffie-Hellman

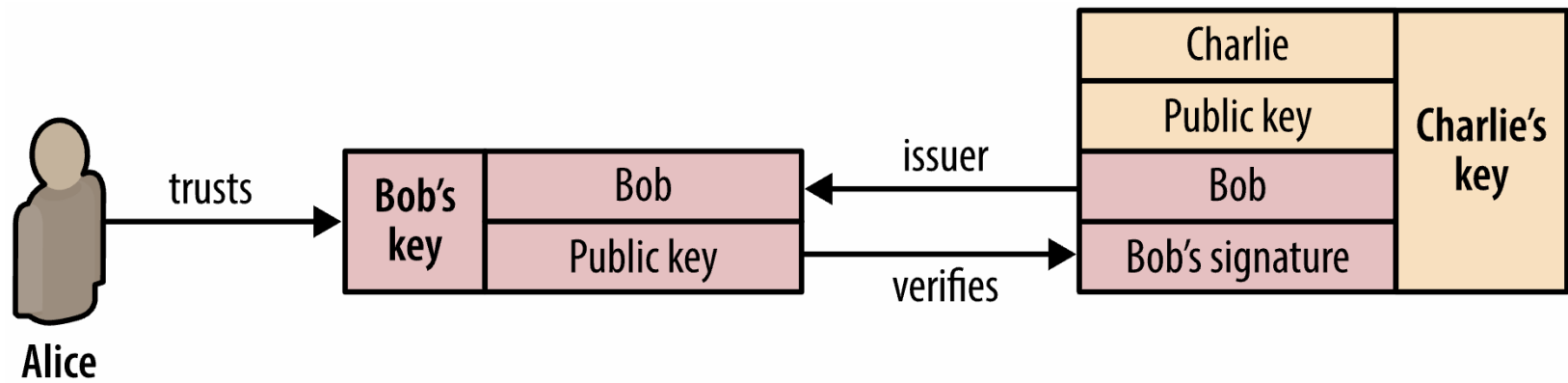
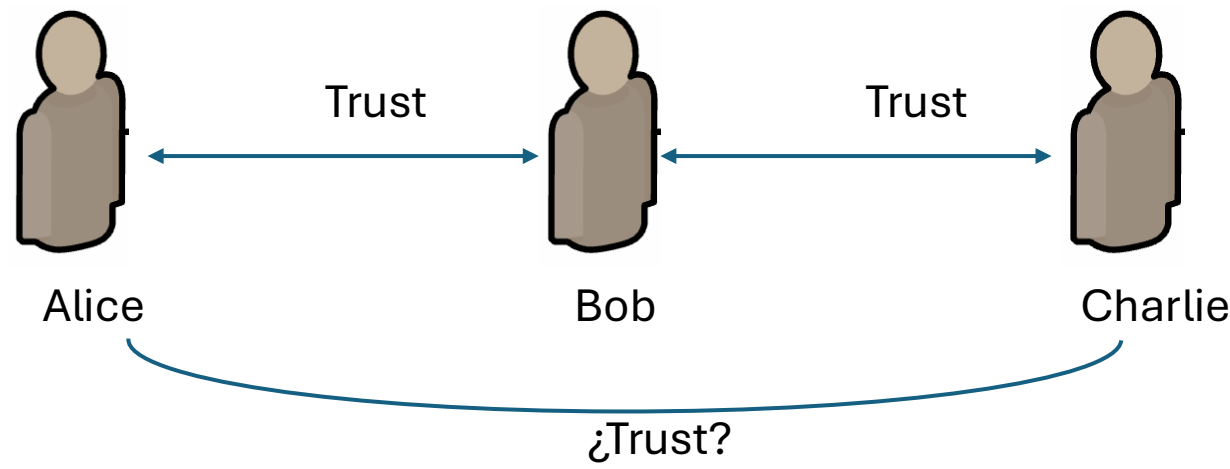
- Cliente y servidor pueden negociar el secreto compartido
- Analogía del funcionamiento (uso de colores)
 - Los peers intercambian un color inicial públicamente
 - Adicionalmente, los peers guardan un color secreto
 - Cada peer mezcla el color público con el color secreto, obteniendo una mezcla distinta cada un.
 - La mezcla se intercambia públicamente
 - Cada peer combina dicha mezcla con su color secreto
 - El resultado es una mezcla final idéntica en cada peer
 - La mezcla final es la clave compartida
- En aplicaciones reales, los colores se reemplazan por números de cierta longitud
- Las claves compartidas son efímeras, es decir, se negocia una distinta por cada sesión.



Criptografía de clave pública VS Criptografía de clave simétrica

- La criptografía de clave pública se utiliza durante la configuración del túnel TLS.
 - Se autentican los certificados
 - Se ejecuta el algoritmo de intercambio de claves
- La criptografía de clave simétrica, utiliza dicha clave para toda la comunicación posterior entre cliente y servidor, dentro de la sesión.
- La criptografía de clave pública es más costosa computacionalmente.

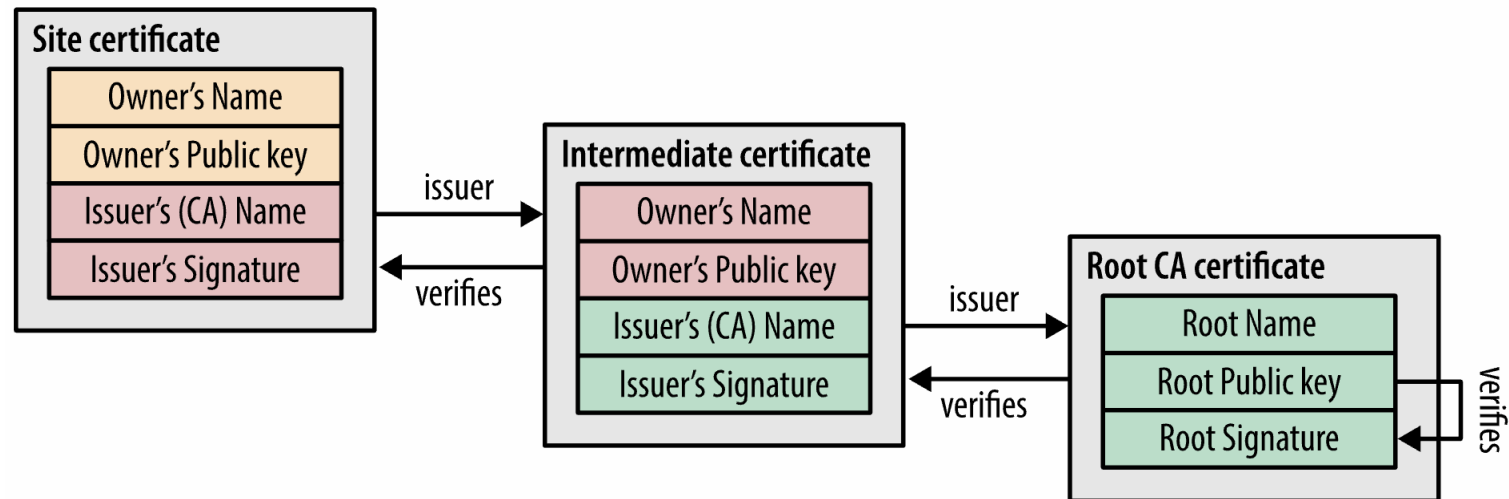
Cadena de confianza



Cadena de confianza Alice, Bob, Charlie

Autoridades de certificación

- Cuando se navega en la Web de forma segura, se establece una cadena de confianza.
- Debe haber una entidad en la que confíe el usuario y el navegador
 - Certificado especificado manualmente (lo obtiene el usuario y lo importa)
 - Autoridad Certificadora (CA)
 - Navegador y sistema operativo. El S.O. y la mayoría de los navegadores incluyen una lista de autoridades de certificación conocidas



Protocolo de registro TLS

Byte	+0	+1	+2	+3
0	Content type			
1..4	Version		Length	
5..n	Payload			
n..m	MAC			
m..p	Padding (block ciphers only)			

Para la entrega de datos a la aplicación:

- Se reciben los datos de la aplicación
- Los datos se dividen en bloques de máximo 16 KB
- A cada registro se le añade un Código de Autenticación de Mensaje (MAC) (hasta 32 bytes para TLS 1.2)
- Los datos de cada registro se cifran utilizando el algoritmo acordado
- Content Type. Identifica los diferentes tipos de mensajes (handshake, alerta – warning o fatal -, datos)

Todo este proceso lo gestiona la capa TLS y es transparente para la mayoría de las aplicaciones.

OpenVPN

- OpenVPN es una VPN SSL
- Implementa la extensión de red segura de capa 2 o 3 mediante el protocolo SSL/TLS
- Admite métodos de autenticación de cliente flexibles basados en certificados, tarjetas inteligentes y/o credenciales de nombre de usuario/contraseña
- Permite políticas de control de acceso específicas para usuarios o grupos mediante reglas de firewall aplicadas a la interfaz virtual de la VPN
- OpenVPN 2.0 permite que varios clientes se conecten a un único proceso servidor a través de un único puerto TCP o UDP

Configuración de OpenVPN



Modo de funcionamiento

- Modo Puente (Bridge)
 - Túnel de capa 2
 - El servidor actúa como un switch Ethernet para enlazar a los clientes con dispositivos de la red interna
 - Utiliza interfaz llamada TAP (de Ethernet Terminal Access Point)
 - El cliente obtiene una dirección del mismo rango de los equipos de la red interna
 - Uso principal: acceso a los recursos de la red interna, como equipos compartidos, jugar en LAN, entre otros.
 - Consume mucho ancho de banda
 - No compatible con la mayoría de los dispositivos móviles
 - Configuración más compleja
- Modo enrutamiento
 - Túnel de capa 3
 - Utiliza interfaz llamada TUN (de Túnel)
 - El servidor crea una red distinta para los clientes VPN. Por defecto 10.8.0.0/24
 - El servidor actúa como router entre la red de la VPN y la red local (NAT)
 - Uso principal: acceso a internet seguro
 - No hay paso de paquetes de broadcast
 - Es el modo más utilizado

Requisitos

- Máquina virtual con Debian actualizado y red en modo puente

1) Configuración de Autoridad de Certificación

- Establecer una PKI (infraestructura de clave pública)
 - Requiere certificado independiente para servidor y cada cliente
 - Requiere un certificado y clave de Autoridad de Certificación (CA) maestra para firmar cada uno de los certificados de servidor y de clientes
 - Los relojes del servidor y del cliente deben estar aproximadamente sincronizados, de lo contrario, los certificados podrían no funcionar correctamente.
- Instalar paquetes `openvpn easy-rsa`
- Crear directorio para certificados: ***make-cadir easy-rsa*** (en `/etc/openvpn`)
- Prepara infraestructura de clave pública
 - Desde `easy-rsa/`, ejecutar ***./easyrsa init-pki*** (crea directorio pki: `/etc/openvpn/easy-rsa/pki`)
- Construir certificado y clave de la Autoridad de Certificación (CA): ***./easyrsa build-ca***
 - IMPORTANTE: Recordar la frase solicitada, se requiere para firmar certificados posteriormente
 - Crea llave pública (certificado) en `pki/ca.crt` y clave privada en `pki/private/ca.key`

2) Crear certificado del Servidor

- Crear claves (pública y privada) del servidor:
 - ***./easyrsa gen-req servidor-feiuv nopass***
 - Genera clave privada en pki/private y clave pública en pki/reqs.
 - El parámetro *nopass* significa que la clave privada no estará protegida por una contraseña
- Firmar certificado (clave pública del servidor):
 - ***./easyrsa sign-req server servidor-feiuv***
 - Solicita contraseña que se dio a la entidad certificadora (pass phrase)
 - Genera certificado del servidor (clave pública certificada por la CA) en pki/issued

3) Crear certificado del Cliente

- Crear claves para cliente (desde openvpn/easy-rsa):
 - ***./easyrsa gen-req cliente1-feiuv nopass***
- Firmar requerimiento del cliente:
 - ***./easyrsa sign-req client cliente1-feiuv***

4) Autenticación y cifrado

- Se agrega una capa de seguridad adicional para la Autenticación HMAC (Hash-based Message Authentication Code)
 - Crear clave ta.key
 - Método TLS-Auth: solo firma los paquetes iniciales
 - Método TLS-Crypt: firma y cifra todo el canal de control
- Crear la clave TLS CRYPT (capa de seguridad adicional).
 - ***openvpn --genkey secret ta.key*** (desde el directorio openvpn/server.

5) Configurar servidor (1/3)

- Hacer respaldo de la documentación
 - Copiar /usr/share/doc/openvpn a /etc/openvpn/doc
 - Copiar archivo de configuración de ejemplo desde la documentación, a openvpn/server
 - ***cp openvpn/doc/examples/sample-config-files/server.conf openvpn/server***
- Editar server.conf
 - IMPORTANTE: hacer copia de los siguientes archivos en el directorio openvpn/server:
 - ca.crt
 - servidor.crt
 - servidor.key
 - ta.key

5) Configurar servidor (2/3) – Archivo server.conf

- Los nombres de los archivos deben coincidir y estar en el mismo directorio:
 - ca ca.crt
 - cert servidor.crt
 - key servidor.key # This file should be kept secret
- Deshabilitar Diffie-Hellman
 - ;dh dh2048.pem
 - dh none
- Habilitar topología de subred
 - topology subnet
- Habilitar acceso a la red detrás del servidor (Validar IP)
 - push "route 192.168.1.0 255.255.255.0"
- Habilitar para que los clients usen default gateway a través del túnel
 - push "redirect-gateway def1 bypass-dhcp"

5) Configurar servidor (3/3) – Archivo server.conf

- Asignar DNS a los clients
 - push "dhcp-option DNS 208.67.222.222"
 - push "dhcp-option DNS 208.67.220.220"
- Habilitar clave de cifrado adicional
 - ;tls-auth ta.key 0
 - tls-crypt ta.key 0
- Indicar algoritmo de cifrado
 - ;cipher AES-256-CBC
 - cipher AES-256-GCM #OFRECE CIFRADO Y AUTENTICACION
 - auth SHA512
- Sin permisos de usuario y de grupo
 - ;user openvpn
 - ;group openvpn
 - user nobody
 - group nogroup

6) Configuración del cliente (1/2)

- Crear archivo de configuración del cliente
 - ***cp openvpn/doc/examples/sample-config-files/client.conf openvpn/client***
 - IMPORTANTE: Verificar correspondencia de parámetros entre cliente y servidor
- Editar client.conf
 - Agregar IP del servidor y puerto
 - remote 192.168.1.123 1194
 - Sin permisos de usuario y de grupo
 - ;user openvpn
 - ;group openvpn
 - user nobody
 - group nogroup
 - Comentar: esta información se incluirá en archive .ovpn del cliente
 - ;ca ca.crt
 - ;cert client.crt
 - ;key client.key
 - ;tls-auth ta.key 1
 - Habilitar mismo cifrado que en el servidor
 - ;cipher AES-256-CBC
 - cipher AES-256-GCM
 - auth SHA512

7) Agregar reglas al Firewall

- Openvpn crea una interfaz virtual (tun0). Se tiene que permitir el reenvío de paquetes entre la interfaz virtual y la física para permitir acceso a Internet
- Permitir reenvío de paquetes cada que se inicia el equipo:
 - Editar archivo **/etc/sysctl.conf** (para configurar parámetros del kernel)
 - Quitar comentario a **net.ipv4.ip_forward=1**
 - Agregar “1” al archivo ip_forward (permite el reenvío en la sesión actual: **echo 1 > /proc/sys/net/ipv4/ip_forward**)
- Agregar reglas al firewall (iptables):
 - **iptables -t nat -I POSTROUTING 1 -s 10.8.0.0/24 -o eth0 -j MASQUERADE** (todo lo que entre por una ip privada saldrá por la IP “pública”)
 - **iptables -I INPUT 1 -i tun0 -j ACCEPT** (acepta todo lo que entre por la interfaz virtual)
 - **iptables -I FORWARD 1 -i eth0 -o tun0 -j ACCEPT** (permite reenvío de la interfaz física a la virtual)
 - **iptables -I FORWARD 1 -i tun0 -o eth0 -j ACCEPT** (permite reenvío de la interfaz virtual a la física)
 - **iptables -I INPUT 1 -i eth0 -p udp --dport 1194 -j ACCEPT** (acepta todo lo que entre por la interfaz física, específicamente al puerto udp indicado)

8) Configurar servicio Openvpn

- Hacer las reglas del firewall persistentes (aunque se reinicie el equipo)
 - instalar **iptables-persistent**
 - guardar reglas: ***netfilter-persistent save***
- Configurar openvpn para que inicie en el arranque e iniciar servicio
 - ***systemctl -f enable openvpn-server@server.service***
 - ***service openvpn-server@server start***

9) Crear archivos de cliente (1/2)

- Archivo para conexión de cliente incluye:
 - Client.conf
 - Certificado de la Autoridad Certificadora (ca.crt)
 - Certificado del cliente (cliente.crt)
 - Clave privada cliente (cliente.key)
 - Clave privada tls-crypt (ta.key)
- Hacer copia de **client.conf** (mismo directorio), como **pantilla.conf**
- Copiar en client/keys:
 - ca.crt
 - cliente.crt
 - cliente.key
 - ta.key
- Crear script para generar archivo .ovpn

9) Crear archivos de cliente (2/2)

- Script para generar archivo .ovpn del cliente (**make_config.sh**):

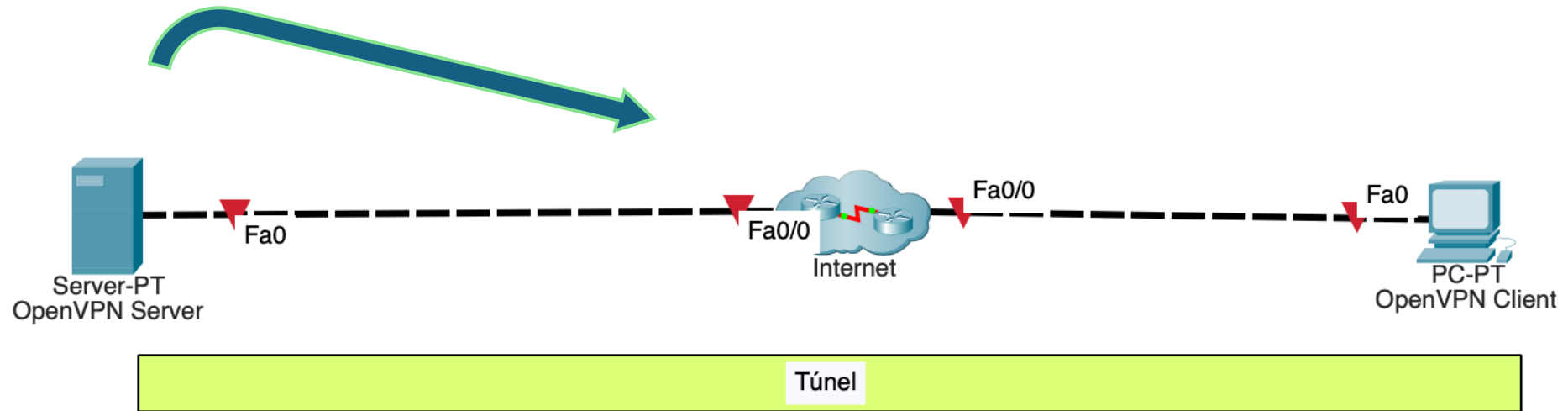
```
#!/bin/bash
#Requiere argumento: Identificador del cliente
#
KEY_DIR=/etc/openvpn/client/keys
OUTPUT_DIR=/etc/openvpn/client/files
BASE_CONFIG=/etc/openvpn/client/plantilla.conf

cat ${BASE_CONFIG} \
  <(echo -e '<ca>') \
  ${KEY_DIR}/ca.crt \
  <(echo -e '</ca>\n<cert>') \
  ${KEY_DIR}/${1}.crt \
  <(echo -e '</cert>\n<key>') \
  ${KEY_DIR}/${1}.key \
  <(echo -e '</key>\n<tls-crypt>') \
  ${KEY_DIR}/ta.key \
  <(echo -e '</tls-crypt>') \
  > ${OUTPUT_DIR}/${1}.ovpn
```

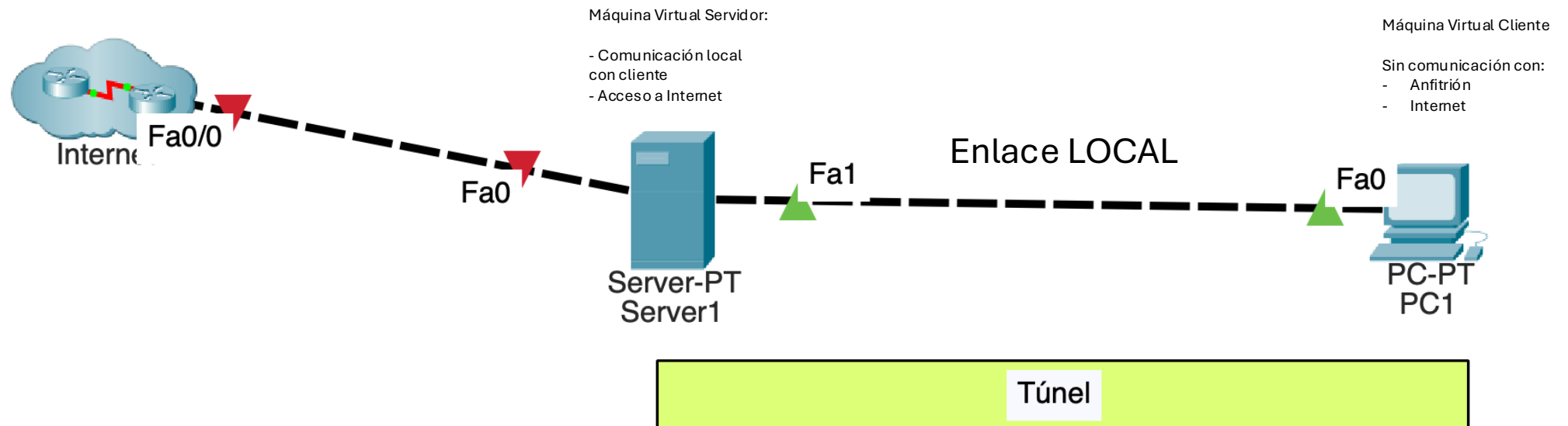

10) Conexión al servidor Openvpn

- Descargar aplicación desde el equipo cliente (OpenVPN Connect)
- Importar archivo .ovpn
- Comprobar navegación a través del servidor VPN

Escenario real



Laboratorio



Referencias

- Snader, J. C. (2006). *VPNs illustrated: Tunnels, VPNs, and IPsec*. Addison-Wesley Professional.
- *Networking 101: Transport Layer Security (TLS) - High Performance Browser Networking* (O'Reilly). (s/f). High Performance Browser Networking. <https://hpbwn.co/transport-layer-security-tls/>
- Diffie–Hellman key exchange. (2026). En *Wikipedia*. https://en.wikipedia.org/w/index.php?title=Diffie%E2%80%93Hellman_key_exchange&oldid=1341912569
- *OpenVPN Community Documentation*. (s/f). <https://openvpn.net/community-docs/?lang=en>